Stoquify Platform Hardening Final Readiness — 2026-07-28

Executive verdict

NOT READY FOR ENTERPRISE PRODUCTION CERTIFICATION.

This run materially reduced three immediate risks and established a professional, dependency-ordered remediation system. It did not—and under the program stop rules could not—complete platform hardening. Two identified paths are verified remediated at their tested boundary, one P0 financial risk is safely contained, fifteen findings remain partially remediated, and three remain blocked by external or deployment evidence.

Status summary

- Findings: 20.
- Verified remediated: 2 (`INC-002` , `INC-007`).
- Partially remediated: 15, including store-credit containment.
- Blocked external/deployment: 3 (`INC-012` , `INC-013` , `INC-017`).
- Focused tests in final combined run: 31 passed (14 POS + 17 security/purchasing).
- Earlier trusted-origin attempt: failed due test fixture, preserved in evidence.
- Static schema/type/boundary/delete/assurance gates: passed.

What is stronger now

- Untrusted request Host headers cannot expand BetterAuth trusted origins.
- Generic bulk purchase-order approval cannot bypass canonical maker-checker identity/evidence.
- Store-credit sale attempts stop before the transaction and financial effects.
- A complete ownership, migration, projection, test and rollout plan now governs remaining work.

Critical unresolved risks

1. ADR-0002 tenant-scoped Prisma protection remains absent; service filters are still the active DB defence.
2. Store credit has no authoritative ledger; it is disabled, not completed.
3. Electronic capture and non-cash refunds remain locally assertable without provider-authoritative settlement.
4. Customer and drawer balance updates remain concurrency-sensitive.
5. Cash/AR projections remain semantically inconsistent.
6. Critical audit remains best-effort and invitation tokens remain plaintext.
7. Entitlement enforcement and offline original-actor authority remain incomplete.
8. Inventory replay/AP exception races remain unresolved.
9. Migration history, managed secrets and production observability remain blocked/unverified.
10. Statutory sources, expert approval and authority conformance remain blocked.

Release recommendation

Hold production promotion and certification. Preserve the containment changes. Next execute the tenant/control-plane structural slice in an isolated, clean candidate with an approved ADR, additive migration rehearsal, rollback proof and cross-tenant adversarial tests. Then implement financial truth before modifying dashboard semantics.

Independent review requirement

The implementers do not provide final security, accounting, statutory or production certification. A separate reviewer must validate the clean diff, migration rehearsal, tenant tests, provider evidence, reconciliation, observability and rollback drills.